

第四輪小白卡關修補法律與合規警告 (v3.40)



本檔性質：相對日期解析 / 應收帳齡 / hard-write 凍結 / Audit 跨人搜尋 / 訂單比較 / Delete undo 之合規提醒，不構成法律意見。累積適用於 v3.25.10 → v3.39 全部 §6 聲明。

English version: [POLISH_V340_LEGAL_NOTICE_EN.md](#)

⚠️ 客戶務必由 CPA / 法律顧問 / 內控主管覆核本檔後正式上線。

⚠️ v3.40 涉及之高度敏感功能

功能	風險等級	法律敏感度
凍結 hard-write 安全模式 (M5)	● 全系統影響	公司治理、內控合規
Delete undo (90 秒復原) (M4)	● 資料還原	個資法、營業秘密法
Audit log 跨人搜尋 (M6)	● 員工監督	勞動法、個資法
應收帳齡查詢 (M2)	● 客戶財務狀況	商業會計法、個資法
訂單比較 (M7)	● 內部使用	商業機密
相對日期解析 (M1)	● 純 helper	—

1. 凍結 hard-write 安全模式 (M5)

1.1 行為

- 公司負責人 / 系統管理員講「凍結 hard-write 14 天」
- 凍結期間：所有寫入類 LLM tool 全系統拒絕執行
- 查詢類 (READ) 正常
- 解凍工具本身不被攔截 (避免鎖死)

1.2 高權限敏感

- 此功能可癱瘓全公司業務寫入流程
- 僅限 `system.config.update` 權限之使用者可執行

- 客戶必須：
 - 限制此權限給**公司負責人 + 1 名備援**
 - 凍結前**書面通知**全體員工
 - 解凍後**書面通知**並恢復作業

1.3 法律風險

凍結期間可能造成：

- ● 客戶下單失敗 → 商業損失 / 客戶流失
- ● 供應商交期錯失 → 違約金責任
- ● 員工延誤工作 → 勞動契約糾紛
- ● 稅務申報延誤 → 罰鍰

1.4 客戶內控義務

- 凍結必須有**正當理由** (例如：老闆出國、稽核中、資安事件回應)
- 凍結期間**audit log 仍記錄**所有 LLM 對話 + 被拒絕的操作
- 解凍**不會自動補做**凍結期間被拒絕的操作 — 員工須手動重做

1.5 erpilot 免責

於適用法律所允許之最大範圍內，erpilot 對因凍結 hard-write 所衍生之**業務損失、客戶流失、違約金、稅務罰鍰、勞動爭議**等任何損失，**不承擔責任**。

2. Delete Undo (90 秒復原) (M4)

2.1 行為

- 客戶 / 供應商 / 料件刪除後，90 秒內可講「**撤銷**」復原
- 復原時**重建原 row** (含原 ID、原 code、原 created_at)
- 若 90 秒內**該編號被重新使用** → 拒絕復原

2.2 個資法 / 法定保存

刪除動作之**法律意義**並未因 undo 而改變：

- 商業會計法 §38：交易憑證保存 5 年 — **刪除 + 90 秒內復原** 期間，仍視為「**曾刪除**」
- 個資法：客戶之「**忘記權**」行使後，**事後復原**可能違反「**使用者意願**」
- GDPR-equivalent：「**刪除後復原**」可能須通知資料主體

2.3 客戶內控義務

- 刪除應事前審批 (不該以「反正能 undo」為理由放鬆)
- 復原應留 audit log (誰按、為什麼)
- 不應惡意 delete-then-undo 做隱藏紀錄之操作 (已被視為內控違規)

2.4 In-memory 限制

- Undo stack 為單一 process in-memory
- 後端重啟 / Docker compose restart → undo stack 清空
- 多 worker 部署時不共享 (v3.x 路線圖：Redis 共享)
- 客戶不應依賴undo 替代正式備份

2.5 erpilot 免責

erpilot 對 undo 失敗 (後端重啟 / 編號重用 / 過期) 所致之資料無法復原，不承擔責任。

3. Audit Log 跨人搜尋 (M6)

3.1 行為

- 任一登入使用者可講「上個月誰改了客戶 ABC」
- 系統列出actor / action / entity / timestamp

3.2 員工監督邊界

重要：跨人 audit 搜尋涉及員工行為紀錄：

- 屬於勞動法之「員工監察」範疇
- 各國法律對「監察通知 / 知情同意」要求不同
- 台灣：員工應於勞動契約中知悉雇主有監察電子操作紀錄之權
- EU GDPR：須有合法基礎 (contract / consent / legitimate interest)

3.3 客戶內控義務

- 將 audit 搜尋權限僅授予 HR / 法務 / 內稽 / IT 主管
- 員工應簽署「電子操作可被審查」之同意書
- audit 紀錄不得作為人身攻擊或歧視之依據
- audit 紀錄保存期應與人事資料一致

3.4 erpilot 免責

erpilot 對因 audit 搜尋使用不當所致之勞資爭議、隱私訴訟、個資申訴，不承擔責任。

4. 應收帳齡查詢 (M2)

4.1 行為

- 列出客戶 × 應收金額 × 到期日 × 逾期天數
- 含「狀態旗號」 (● > 30 天 / ● 已逾期 / ● 正常)

4.2 法律敏感

應收帳齡資料屬於：

- 客戶之財務狀況 (受個資法第 6 條保護 — 雖非「特種個資」但敏感度高)
- 商業會計法之「對外資料」 (外洩 = 違反保密義務)

4.3 客戶內控義務

- 不得將應收清單寄給未授權之第三方 (含同業、銀行、徵信公司未經客戶同意者)
- 對外提及客戶逾期可能構成毀謗 (須有書面證據)
- 催收行為須遵守金融機構債務催收作業準則 (即使非金融機構，業界類比適用)

4.4 erpilot 免責

erpilot 對因應收帳齡資料外洩、誤用、催收不當所致之毀謗、個資、客戶申訴，不承擔責任。

5. 訂單比較 (M7)

5.1 行為

- 比較兩張 SO/PO：總額、品項數、狀態、客戶/供應商、訂單日

5.2 風險

- 比較結果可能洩漏客戶 A vs 客戶 B 之差別定價 → 違反公平交易法之歧視性定價疑慮 (雖非絕對禁止)
- 比較結果之外洩可能違反營業秘密法

5.3 客戶責任

- 比較結果僅限內部使用
- 不得截圖 / 列印比較結果並外流

6. 相對日期解析 (M1)

6.1 行為

- 「上週」「過去 30 天」「Q1」轉為實際日期

6.2 限制

- 解析基準為伺服器時區 (UTC)
- 客戶若於台灣時區，「今天」於 UTC 凌晨可能差 1 天 — 跨日邊界注意
- 不支援宗教 / 國定假日相對描述 (「中秋節」「春節前」) — v3.x 路線圖

6.3 erpilot 免責

對因日期解析誤差所致之報表錯誤、訂單交期錯算，erpilot 不承擔責任；客戶應人工覆核重要日期計算。

7. 案例：常見錯誤使用模式

7.1 ❌ 不該做

- 凍結 hard-write 期間不通知員工 → 員工以為系統壞了
- 用 Delete-Undo 掩蓋錯誤操作 (如改錯客戶 → delete → undo 假裝沒發生)
- 用 audit 搜尋鎖定特定員工做歧視性對待
- 應收帳齡截圖傳到 LINE 群組討論客戶
- 訂單比較結果寄給對方公司做議價

7.2 ✅ 應該做

- 凍結 hard-write 前公告全公司並設定明確解凍日
- Delete-Undo 用於真正的點錯，並留說明於 audit log
- Audit 搜尋用於內控、稽核、資安事件回應
- 應收清單加密寄會計師
- 訂單比較僅供內部議價策略

8. 免責條款 (累積適用 v3.25.10 → v3.40)

於適用法律所允許之最大範圍內：

1. 凍結 hard-write 凍結為客戶內部決策之執行工具；erpilot 對因凍結造成之業務損失、違約、稅務罰鍰、勞資爭議等任何損失，不承擔責任。

2. **Delete Undo** 為便利性功能；erpilot 對 undo 失敗、誤用、惡意使用所致之法定保存、個資權、契約義務爭議，不承擔責任。
3. **Audit 跨人搜尋** 搜尋為內控工具；erpilot 對因搜尋使用不當所致之勞資爭議、個資申訴、員工歧視主張，不承擔責任。
4. **應收帳齡** 查詢為便利性功能；erpilot 對因資料外洩、誤用、催收不當所致之毀謗、個資、客戶申訴，不承擔責任。
5. **訂單比較** 比較為內部分析工具；erpilot 對因結果外流所致之公平交易、營業秘密爭議，不承擔責任。
6. **相對日期** 解析為啟發式 helper；erpilot 對因日期計算錯誤所致之業務決策錯誤，不承擔責任。

9. 客戶導入前 Checklist (v3.40 補強)

9.1 高權限管控

- ☐ `system.config.update` (凍結權限) 僅授予公司負責人 + 1 名備援
- ☐ `system.audit.read` (如有) 僅授予 HR / 法務 / 內稽 / IT 主管
- ☐ 已建立「凍結公告 → 解凍公告」書面流程

9.2 員工告知

- ☐ 勞動契約 / 員工手冊明確記載：電子操作可被審查
- ☐ 員工簽署同意書 (含電子簽名亦可)
- ☐ 每年至少一次「資安 + 個資」教育訓練

9.3 內控政策

- ☐ 已建立「Delete-Undo 應記原因」之內控規範
- ☐ 已建立「應收清單對外傳遞」之核章流程
- ☐ 已建立「訂單比較結果僅內部使用」之保密政策

9.4 技術配置

- ☐ 後端時區設為台灣 (Asia/Taipei) 或公司所在地 (影響 M1 日期解析)
- ☐ Backup 排程已配置 (M5 凍結期間仍需備份)

9.5 與既有 checklist 累積

- ☐ 已完成 v3.25.10 → v3.39 之全部 checklist

10. 國際法 / 跨國使用警告

若客戶之業務涉及多國市場：

地區	額外法律	對 v3.40 影響
eu EU	GDPR	Delete Undo 須通知資料主體；audit 搜尋須合法基礎
us US (CA)	CCPA	客戶有「刪除請求權」— undo 可能違反
cn China	個人信息保護法	audit 搜尋須合「目的明確、必要、最小範圍」
jp Japan	個人情報保護法	跨境傳輸（如客戶資料）須額外同意
sg SG	PDPA	DNC 名單對應收催收有限制

erpilot 不自動處理跨國合規；客戶須自行諮詢當地法律顧問。

版本：v3.40 (2026-05-21) 作者：erpilot 法務團隊 (內部) 對應程式：

- `backend/app/agents/domains/polish_v340_tools.py` (5 個 LLM tools + helper)
- `backend/app/agents/domains/polish_tools.py` (push_undo + delete 復原邏輯)
- `backend/app/agents/domains/polish_v339_tools.py` (delete 三件套加 push_undo)
- `backend/app/agents/engine.py` (凍結攔截)
- `backend/app/agents/domains/hard_write_tools.py` (case-insensitive search)